

Triage Verdicts for CLD-0101 - CLD-0112

CLD-0101: Failed sign-ins on svc-backup

Alert	Repeated authentication failures on svc-backup@cloudora.io: 18 failures from 203.0.113.20 (LDN-SRV-BK1), 31 Aug 23:41 to 1 Sep 00:03 UTC, success 00:14. Reported High.
Hypothesis	Malicious: internal brute force against a service account from a compromised server. Benign: retry storm from a cached credential during the announced rotation.
Evidence Checked	Change record CHG-2088 (backup credential rotation 23:00 to 02:30, failures expected; window and scope match). Sign-in slice: all 18 failures are error 50126 from the backup server's own address, evenly spaced, ending in a clean success at 00:14 once rotation completed; no other source ever touches the account.
Verdict	False positive (expected maintenance activity).
Severity	Informational. Reported High re-rated down: the failures were announced in advance and access never involved any host but the backup server itself.
Action	Closed, referencing CHG-2088 in the ticket. Recommendation: suppress service-account authentication failures originating from their own hosts during approved change windows.
Justification	Source host, account, time window and recovery all match the announced change; brute force does not stop at 18 attempts, does not originate from the target's own server, and does not resolve exactly when a rotation job completes.
MITRE	None

CLD-0102: Active credential stealer on LDN-WS-117

Alert	Defender AV found Trojan:Win32/Steagen.B (credential stealer) on LDN-WS-117 (liam.doyle). Four detections between 02:3 and 02:41 UTC, quarantine failed each time.
Hypothesis	Malicious: live infection actively resisting removal. Benign: false or stale detection on an already-clean host
Evidence Checked	AV logs show a clean scheduled scan on host on Aug 30 22:14 UTC. Four detections on Sep 1 with escalating failure reasons (file in use, access denied, file recreated) and a second dropped file <code>wsync_upd.exe</code> at 02:31 in the same AppData folder. No relevant explanation in handover. Sign-in slice: No anomalous sign-ins for liam.doyle
Verdict	True Positive; active malware with persistence behavior.
Severity	Sev 2 (confirmed, one host; a credential stealer makes the realistic blast radius the user's accounts, not just the disk)
Action	Isolate LDN-WS-117 via endpoint management; raise an eradication and reimage incident; precautionary password reset and session revocation for liam.doyle; monitor account for anomalous sign-ins over the next 72 hours.
Justification	A false detection does not fail quarantine three different ways and then recreate itself under a new name; regeneration confirms execution.
MITRE	T1204.002 (User Execution: Malicious File)

CLD-0103: Internal Port Scanning

Alert	203.0.113.44 probed 4000+ TCP ports across 180 hosts, 22:10 - 02:5x UTC
Hypothesis	Malicious: internal reconnaissance from a compromised host. Benign: authorized weekly vulnerability scan
Evidence Checked	Handover: authorized vulnerability scanner LDN-SCAN-01 (203.0.113.44) runs its weekly full sweep Monday 22:00 to Tuesday 03:00 UTC
Verdict	False Positive (authorized scanner activity).
Severity	Informational
Action	Closed, referencing the scan schedule. Recommendation: IDS exception for LDN-SCAN-01 during its approved window only.
Justification	Source IP, scope, and timing all match the documented weekly scan. No signs of data transfer
MITRE	None

CLD-0104: Repeated MFA failures to success, nina.cole

Alert	Five MFA denials for nina.cole between 06:31 and 06:47 UTC. New authenticator device registered at 06:50 UTC. Successful sign-in at 06:52. All events from 198.51.100.22 (Manchester office)
Hypothesis	Malicious: MFA fatigue against a known password, attacker registers their own MFA device. Benign: nina.cole had problems with the initial MFA device and registered a new device.
Evidence Checked	Sign-in slice: six sign-in activities all recorded from the usual Manchester office IP on the usual Windows 10/Chrome machine. New device registration timing between failures and success. Helpdesk ticket HD-4471 raised at 07:05 UTC.
Verdict	False Positive (user error with MFA device)
Severity	Informational.
Action	Closed, referencing HD-4471; no reset required.
Justification	Every event originates from the user's known device and location. User opened a matching helpdesk ticket.
MITRE	None

CLD-0105: Suspicious Payslip Email: "Your August payslip is ready"

Alert	james.holt reports an email from payroll@cloudora.io containing a portal link.
Hypothesis	Malicious: attacker spoofing payroll@cloudora.io to steal user credentials. Benign: legitimate monthly payslip email from Cloudora, reported by an overly cautious user
Evidence Checked	Raw headers of 01_reported_payslip_notification.eml: from cloudora.io; SPF, DKIM, and DMARC all pass and align to cloudora.io; Email origin from myhr-notify.cloudora.io (203.0.113.8). Email body states that payroll will not ask to confirm password or bank details by email.
Verdict	False positive (legitimate cloudora email)
Severity	Informational.
Action	Closed, confirmed to the reporter that the email was genuine.
Justification	Email authentication passes aligned to the cloudora domain; message never left cloudora infrastructure
MITRE	None.

CLD-0106: Automated Digest: Device with active unresolved threats

Alert	Automated digest ticket. Trojan:Win32/Stealgen.B remediate incomplete on device LDN-WS-117.
Hypothesis	New event, or a second alerting path re-raising CLD-0102
Evidence Checked	AV log: 08:00 digest line summarizes the detections already found in CLD-0102.
Verdict	Duplicate of CLD-0102
Severity	Not rated; severity tracked on CLD-0102.
Action	Closed as duplicate, cross-reference to CLD-0102.
Justification	One event should only have one ticket carrying the evidence trail; digest adds no new information
MITRE	Tracked on CLD-0102

CLD-0107: Mass File Deletion from SharePoint by Single User

Alert	1,240 files were deleted from SharePoint site "HR-Records-Archive", folder "Leavers-2019" by tara.kemp between 03:00 and 03:20 UTC.
Hypothesis	Malicious: Attacker compromised tara.kemp and destroyed data. Benign: announced annual HR retention cleanup
Evidence Checked	Handover: HR-RetentionFlow executes this under tara.kemp's account, deleting expired records per the seven year policy. The deletion of folder "Leavers-2019" confirms the seven year retention policy. Sign-in slice: tara.kemp account only shows one sign-in activity at 08:09 UTC at the London office; no anomalous access.
Verdict	False positive (automated annual record retention cleanup)
Severity	Informational
Action	Closed, referencing the retention schedule. Recommendation: remove HR-RententionFlow process from the mass-deletion rule
Justification	Initiating process, folder scope, timing all match the scheduled automation.
MITRE	None

CLD-0108: Unfamiliar sign-in from gwen.muir

Alert	One successful sign-in for gwen.muir at 03:54 UTC from 198.18.163.41 (London, UK, residential provider), client IMAP4 (legacy), Windows 10/Firefox. No preceding failures.
Hypothesis	Malicious: use of already-known credentials over a legacy protocol to dodge MFA Benign: user trying a new mail client from home at an odd hour
Evidence Checked	Sign-in Slice: Previous sign in show different device fingerprint (macOS 14/Safari), different IP at 203.0.113.12, and show no indication of previous IMAP usage.
Verdict	True Positive (probable account compromise using externally obtained credentials)
Severity	Sev 2. Probable confirmed access to one standard account.
Action	Revoke all sessions of the account and reset the password; block legacy authentication (this event shows IMAP is still allowed and can bypass MFA); gather information about how the password was initially leaked and whether other accounts show sign-in activities using IMAP
Justification	A clean first-try sign-in success is an indication of credential use, since a brute-force or password-spray attempts would typically show prior failures. The device fingerprint and IP differ from the user's established pattern (macOS/Safari, 203.0.113.12), and the account had no prior history of IMAP usage, indicating the attacker pivoted to a legacy protocol specifically to bypass MFA
MITRE	T1078.004 (Valid Accounts: Cloud Accounts), via legacy protocol to bypass MFA

CLD-0109: Repeated outbound connections to rare external host

Alert	Since 07:40 UTC, LDN-WS-104 (aria.reid), MAN-LT-033 (finn.gale), and AUS-WS-208 (dean.page) have made outbound connection to 198.18.207.66 roughly every 60 seconds.
Hypothesis	Malicious: C2 beaconing from a coordinated infection. Benign: an undocumented agent or update service polling home.
Evidence Checked	Three hosts from three different offices are making outbound connections to a single rare external host at a fixed interval, starting around the same time. Sign-in slice: no anomalous sign-ins from any of the three hosts. Handover: no change record or any information explaining the behavior.
Verdict	Escalate
Severity	Sev 2 (possible malware on multiple hosts)
Action	Escalate to vCISO with the alert detail, host and user list, the beacon pattern, and the absence of an explaining change. Request endpoint forensics on the three hosts and egress capture for 198.18.207.66.
Justification	Network pattern matches C2 beaconing, and even the benign explanation still requires investigation beyond triage.
MITRE	Suspected T1071.001 (Application Layer Protocol: Web Protocols)

CLD-0110: Blocked Sign-in Attempts from a watchlist IP

Alert	Three sign-in attempts for daniel.reeve@cloudora.io between 05:09 and 05:11 UTC from 102.89.44.17 (Lagos, Nigeria). All returning error 53003, blocked by Conditional Access policy.
Hypothesis	Legitimate attacker activity; IP is on tenant block list from CLD-0001
Evidence Checked	Sign-in slice: All three attempts from Lagos, Nigeria, returned 53003, meaning that the attempt is blocked at policy, before credentials are even validated. No sign of success sign-in from 102.89.44.17. The CLD-0001 block covering all three Lagos IPs remains in place
Verdict	True positive activity with no impact
Severity	Sev 4 (blocked by control)
Action	Monitor any non-54003 result from 102.89.x.x or attempts against any additional accounts. Verified the block still covers all three known IPs.
Justification	53003 proves the requests died at policy; no evidence of impact anywhere in the data
MITRE	T1110.003 (Password Spraying) attempted; continuation of the CLD-0001 campaign

CLD-0111: Suspicious Invoice Email: "Overdue invoice INV-2214"

Alert	At 08:19 UTC, lucas.ford reported an email from billing@meridianoffice.example with an attachment "INV-2214.pdf".
Hypothesis	Malicious: invoice-lure with a weaponized attachment aimed at finance. Benign: a real supplier reminding the company of a real invoice
Evidence Checked	02_reported_supplier_invoice.eml: SPF passes for meridianoffice.example; DKIM=none and DMARC=none. Return-path and reply-to all align; body has plausible invoice text with mild urgency.
Verdict	Insufficient Data
Severity	Sev 4 (On hold awaiting evidence)
Action	Confirm with finance that Meridian Office Supplies is a genuine supplier with an open invoice INV-2214; open the attachment in the sandbox; follow up with the reporter, confirming whether they opened the attachment and on what device.
Justification	Closing a legitimate phishing email risks leaving a weaponized invoice in staff accounts. Calling it phishing without evidence ruins connection with a real supplier.
MITRE	None yet; T1566.001 (Spearphishing Attachment) if the attachment is confirmed malicious.

CLD-0112: Impossible travel: omar.farah

Alert	omar.farah signs in from Dubai, United Arab Emirates at 05:58 UTC and then from London, United Kingdom at 06:40 UTC. Sign-in activity is 42 minutes apart but the two locations are roughly a seven hour flight apart.
Hypothesis	Malicious: an attacker using his credentials from one of the two locations. Benign: a corporate device generating London events while he travels.
Evidence Checked	Sign-in slice: London Aug 31 18:22, Dubai Sep 1 05:58 and 07:31:29 are all from the same iPhone and all successes on first try. The sign in on Sep 1 06:40 from London is on a Windows 11 and Edge with the result "Success (non-interactive token refresh)", indicating that his office device is renewing an existing session from the office with no credentials entered by anyone.
Verdict	False Positive (the London activity is not a person. Legitimate travel plus a stationary registered device's token refresh)
Severity	Informational.
Action	Closed, sign-in logs and CLD-0001 travel history. Recommendation: exclude non-interactive sign-ins from impossible travel pairing.
Justification	A real dual-location compromise shows interactive authentication or activity from an unknown device. The logs show every interactive event on his own device in a pattern matching a documented trip. Contrast this to CLD-0001, where Daniel's foreign activity was on a never-seen device at 3AM with failures prior.
MITRE	None

End of Shift Summary

Alert	Verdict	Sev	Action
CLD-0101	False positive (expected maintenance activity)	Info	Closed; suppress failure during change windows rec
CLD-0102	True Positive (active malware with persistence behavior)	Sev 2	Isolated; incident raised; user creds reset
CLD-0103	False Positive (authorized scanner activity)	Info	Closed; IDS exception for scanner
CLD-0104	False Positive (user error with MFA device)	Info	Closed
CLD-0105	False positive (legitimate cloudora payslip email)	Info	Closed, confirmed legitimacy to reporter
CLD-0106	Duplicate of CLD-0102	N/A	Closed; referenced CDR-0102
CLD-0107	False positive (automated annual record retention cleanup)	Info	Closed; remove retention flow deletion from rule rec
CLD-0108	True Positive (probable account compromise using externally obtained credentials)	Sev 2	Contained; block legacy authentication rec; revoke sessions & incident response
CLD-0109	Escalate (multi-site C2 beaconing)	Sev 2	Escalate to vCISO; request forensics
CLD-0110	True positive (blocked, activity with no impact)	Sev 4	Monitor Lagos IPs; reference CLD-0001
CLD-0111	Insufficient Data, awaiting evidence	Sev 4	On hold; gather evidence about sender
CLD-0112	False Positive (Legitimate travel plus registered device's token refresh)	Info	Closed; remove non-interactive sign-ins from travel rule rec

Still Open Tickets: CLD-0102 and CLD-0108 as incidents, CLD-0109 with the vCISO, CLD-0111 awaiting evidence.

Escalated: CLD-0109 requires further investigation through forensics

Tuning Recommendations: Five tuning changes below, which would have removed five of the seven false positives.

Tuning Table

Rule	Problem	Proposed Change	Risk of the Change
Service account authentication failures	Fires on announced credential rotations	Suppress failures from account's own host during approved change windows	Attacks during the change windows from that host would be muted
IDS port scanning	Fires on weekly scans	Exception for authorized scanner LDN-SCAN-01 during approved window only	Compromised scanner will go undetected during scan window
Defender Digest connector	Duplicates real-time alerts	Correlate to existing tickets or remove digest ticketing	Digest tickets may correlate a new event into an old ticket
Mass Deletion	Fires on sanctioned retention flow	Exclude HR-RetentionFlow from mass deletion rule	If the account executing HR-RetentionFlow was compromised, the activity would be muted.
Atypical Travel	Triggers on non-interactive events	Exclude non-interactive sign-ins from triggering atypical travel rule	Non-interactive attacks (such as token-replay) would go unnoticed

Final Summary

Most dangerous alert: CLD-0109; if confirmed as C2 beaconing, this would mean that the attacker already has a foothold on multiple hosts and a working C2 channel, which is a much larger problem than a single compromised account. It is also the alert that triage alone could not resolve, and needed to be escalated to vCISO to request forensics.

The one that I would have got wrong a month ago: CLD-0108; this alert could easily have been looked over due to the London sign-in activity, and read as the user just working from home on a personal laptop. It was the combination of a brand new device, a legacy protocol that happens to skip MFA, and a clean first-try login that made credential-theft the more likely story than a new-laptop explanation.